UNIVERSITY OF BOTSWANA

Department of Computer Science

LAB REPORT

CSI454: Ethical Hacking Essentials

Module 04: Password Cracking Techniques and Countermeasures

Submitted by:

BOITSHOLO RAMOKHUA

Student ID: 202202152

1. Objectives

The objectives of this laboratory exercise are drawn from the EC-Council Ethical Hacking Essentials (EHE) Module 04 curriculum, covering both Lab 3 (Active Online Attacks) and Lab 2 (Password Auditing):

1. Perform an active online attack using Responder to intercept LLMNR/NBT-NS broadcast requests on the local network and capture NTLMv2 password hashes from a victim Windows 10 machine.
2. Use John the Ripper to crack the captured NTLMv2 hash and recover the plaintext password of the victim user (Jason).
3. Audit system passwords on a remote Windows Server 2016 machine (10.10.1.16) using L0phtCrack 7, importing password hashes via SMB and performing a Thorough Password Audit.
4. Create local user accounts on the Parrot Security machine, combine /etc/passwd and /etc/shadow using the unshadow utility and use John the Ripper with a custom wordlist to crack the resulting Linux password hashes.

All activities were conducted in an authorised EC-Council iLabs virtual environment using Parrot Security 4.10, Windows 10 and Windows Server 2016 virtual machines.

2. Use of Recommended Tools

2.1 Responder

Responder is an LLMNR, NBT-NS and MDNS poisoner. It responds to specific broadcast name resolution requests on a local network, spoofing the legitimate server and capturing NTLMv2 authentication hashes from victim machines that attempt to access non-existent network resources. Used on: Parrot Security 4.10 (attacker), targeting Windows 10 (10.10.1.10).

2.2 John the Ripper

John the Ripper (JtR) is an open-source password security auditing and recovery tool. It supports hundreds of hash types including NTLMv2 (used in Lab 3) and SHA-512crypt Linux hashes (used in Lab 2). In Lab 3 it was used to crack the captured NTLMv2 hash using a default wordlist. In Lab 2 it was used with a custom Passwords.txt wordlist against Linux /etc/shadow hashes after unshadowing.

2.3 L0phtCrack 7 (LC7)

L0phtCrack is a Windows password auditing tool that can import NTLM hashes from local or remote machines via SMB. In this lab, it was configured to connect to the remote Windows Server 2016 machine (10.10.1.16) using Administrator credentials, extract all NTLM hashes and perform a Thorough Password Audit combining dictionary and brute-force attacks.

3. Clear Evidence of Research

3.1 LLMNR/NBT-NS Poisoning and Credential Capture

Link-Local Multicast Name Resolution (LLMNR) and NetBIOS Name Service (NBT-NS) are Windows name resolution protocols that broadcast queries on the local subnet when DNS fails. Because these protocols operate without authentication, an attacker on the same network can respond to these broadcasts impersonating the requested host . When a victim machine accepts the poisoned response and attempts authentication, it transmits an NTLMv2 challenge-response hash which the attacker's tool captures.

This attack, facilitated by tools such as Responder, is classified under MITRE ATT&CK as T1557.001: Adversary-in-the-Middle: LLMNR/NBT-NS Poisoning and SMB Relay . Since LLMNR and NBT-NS are enabled by default on Windows, the attack surface is wide in enterprise environments where these services have not been explicitly disabled.

3.2 NTLM Hash Cracking with John the Ripper

NTLM (NT LAN Manager) is Microsoft's legacy authentication protocol. NTLMv2, while stronger than NTLMv1, is still vulnerable to offline dictionary and brute-force attacks once the hash is captured . John the Ripper performs this by comparing hashed versions of candidate passwords against the captured hash. A weak password such as 'qwerty' is trivially recoverable from a basic password wordlist .

Password salting, complexity requirements and multi-factor authentication are the primary mitigations against NTLM hash cracking. The EC-Council EHE curriculum recommends disabling LLMNR and NBT-NS at the Group Policy level to prevent hash capture in the first place .

3.3 Password Auditing with L0phtCrack

L0phtCrack (LC7) is a purpose-built Windows password auditing tool that imports NTLM hashes directly from SAM databases or remote machines via SMB . A Thorough Password Audit combines dictionary attacks with jumbo permutations followed by a 6-hour brute-force using a large ASCII character set. Cracked passwords are presented in plaintext alongside their NTLM hashes, allowing administrators to identify accounts with weak passwords.

Passwords cracked in seconds or minutes (e.g., 'apple' in 9 seconds, 'qwerty' in 31 seconds) indicate a violation of organisational password policy. These should trigger immediate forced password resets and implementation of a stricter password policy .

3.4 Linux Password Auditing with John the Ripper and Unshadow

Linux systems store password hashes in /etc/shadow, separated from /etc/passwd to prevent unprivileged read access. The unshadow utility merges these two files into a combined format that John the Ripper can process . This lab used SHA-512crypt (6) hashes, the current default on most Linux distributions. John the Ripper was directed at these hashes using a custom Passwords.txt wordlist, successfully cracking 4 of 7 accounts in under 2 seconds, confirming that the chosen passwords (alpha, apple, qwerty@123, test@123) were weak and present in the wordlist .

4. Screenshots with Descriptions of Evidence Simulation

Lab 3, Task 1: Perform Active Online Attack Using Responder

Lab Environment: Parrot Security 4.10 (attacker, IP: 10.10.1.9), Windows 10 (victim, IP: 10.10.1.10). The goal was to use Responder to capture the NTLMv2 hash of user Jason on Windows 10 and crack it using John the Ripper.

Figure 1: Responder Launched sudo responder -I eth0

On the Parrot Security machine, a terminal was opened and the command 'sudo responder -I eth0' was executed. The -I flag specifies the network interface (eth0). The sudo password 'toor' was entered. Responder began initialising its listeners, generating Python SyntaxWarnings from legacy code. This initiated the LLMNR/NBT-NS poisoning process on the network.

Figure 1: Terminal showing sudo responder -I eth0 command executed on Parrot Security

Figure 2: Responder Active All Poisoners and Servers Running

After initialisation, Responder displayed its active configuration: Poisoners LLMNR [ON], NBT-NS [ON], DNS/MDNS [ON] and Servers including HTTP, HTTPS, SMB, Kerberos and others. The tool was now listening on the network for broadcast name resolution requests from any Windows machine on the subnet.

Figure 2: Responder listening LLMNR, NBT-NS, DNS/MDNS poisoners active

Figure 3: Victim Triggers Hash Capture Network Error on Windows 10

On the Windows 10 machine, the Run window was used to navigate to \\CEH-TOOLS. Because CEH-TOOLS does not exist on the network, Windows 10 sent an LLMNR/NBT-NS broadcast to resolve the name. Responder intercepted this broadcast and returned a poisoned response. Windows 10 then attempted NTLM authentication with Responder, resulting in a 'Windows cannot access \\CEH-TOOLS' error on the victim but triggering hash capture on the attacker.

Figure 3: Windows 10 victim receives Network Error accessing \\CEH-TOOLS, triggering NTLMv2 hash capture

Figure 4: NTLMv2 Hash Captured for WINDOWS10\Jason

Returning to the Parrot Security terminal, Responder displayed the captured credentials: [SMB] NTLMv2-SSP Client: 10.10.1.10, Username: WINDOWS10\Jason and the full NTLMv2-SSP Hash. The hash is the complete NTLMv2 challenge-response blob that can be passed to John the Ripper for offline cracking. Responder also noted 'Skipping previously captured hash for WINDOWS10\Jason', confirming it had stored the hash in /usr/share/responder/logs.

Figure 4: Responder captures full NTLMv2 hash for WINDOWS10\Jason (10.10.1.10)

Figure 5: Captured Hash Saved to hash.txt

The NTLMv2 hash was copied from the Responder terminal output and pasted into a new file, hash.txt, opened via 'sudo su' then 'pluma hash.txt'. The hash was saved in the format required by John the Ripper:
Jason::WINDOWS10:1db37810dc0aaee3:A96E62CB8530F63F0DC824FB93054497:... The file was saved and closed.

Figure 5: NTLMv2 hash for WINDOWS10\Jason pasted into hash.txt for John the Ripper

Figure 6: John the Ripper Cracks the Hash Password: qwerty

The command 'john hash.txt' was executed in the terminal. John the Ripper loaded 1 NTLMv2 hash (netntlmv2, MD4 HMAC-MD5 32/64) and processed it using its default wordlist (/usr/share/john/password.lst). The crack completed rapidly, displaying: 'qwerty (Jason)'. The session completed with the password 'qwerty' identified in plain text for user Jason, confirming a successful active online password attack.

Figure 6: John the Ripper cracks NTLMv2 hash qwerty (Jason) using default wordlist

Figure 7: Lab Question 14.1.1.1 Correct Answer: -I eth0

The lab question asked: 'Find the NTLM hash for user Jason on Windows 10 and enter the name of the interface used while running Responder.' The answer '-I eth0' was entered and scored Correct, confirming the interface flag used in the Responder command.

Figure 7: Lab Question 14.1.1.1 answered correctly Responder interface flag: -I eth0

Lab 2, Task 1: Audit System Passwords Using L0phtCrack

Lab Environment: Windows 10 (running L0phtCrack), targeting Windows Server 2016 (10.10.1.16, Administrator/Pa$$w0rd, domain: EHE.com). The goal was to extract and crack NTLM password hashes from the remote Windows Server 2016 machine.

Figure 8: LC7 Wizard Choose Target System Type: Windows

After installing L0phtCrack 7 and launching the Password Auditing Wizard, the 'Choose Target System Type' screen was shown. The Windows radio button (Desktops: Windows XP through 10 / Servers: Windows Server 2003 or greater) was selected and Next was clicked, configuring LC7 to extract Windows NTLM hashes.

Figure 8: LC7 Password Auditing Wizard Choose Target System Type: Windows selected

Figure 9: LC7 Wizard Windows Import: Remote Machine via SMB

In the Windows Import step, 'A remote machine' was selected. This requires admin privileges on the remote machine and uses the SMB protocol to extract password hashes remotely without needing physical access. Next was clicked to proceed to the remote machine configuration.

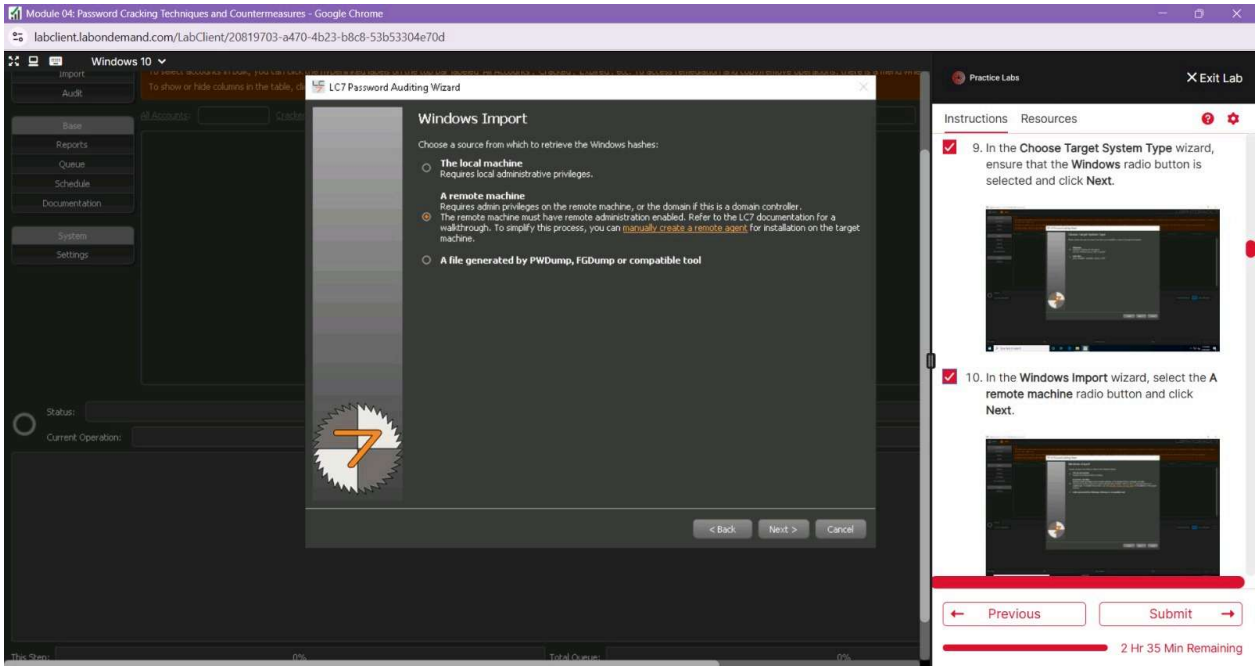

Figure 9: LC7 Wizard Windows Import: 'A remote machine' selected for SMB hash extraction

Figure 10: LC7 Wizard Remote Machine SMB Configuration

The 'Windows Import From Remote Machine (SMB)' screen was configured with: Host: 10.10.1.16 (Windows Server 2016), Use Specific User Credentials selected, Username:

Administrator, Password: Pa$$w0rd, Domain: EHE.com. This authorised LC7 to connect to the target machine and extract all NTLM password hashes via the SAM database over SMB.

Figure 10: LC7 SMB configuration Host 10.10.1.16, Administrator credentials, EHE.com domain

Figure 11: LC7 Wizard Thorough Password Audit Selected

In the Choose Audit Type screen, 'Thorough Password Audit' was selected. This method checks passwords against a dictionary with extensive permutations, followed by a 6-hour brute-force attack using a large ASCII character set. Dictionary: wordlist-huge.txt, 78,571 words. Brute Force: letters, numbers, symbols, 10-character limit, 6-hour maximum.

Figure 11: LC7 Wizard Thorough Password Audit selected with dictionary and brute-force parameters

Figure 12: LC7 Wizard Audit Summary Before Execution

The Summary wizard displayed all configured actions before execution: Import hashes from 10.10.1.16 via SMB using Administrator credentials in domain EHE.com; Perform 'thorough' audit (user-info single mode, dictionary attack with jumbo permutations, 6-hour brute-force ASCII); Export CSV report to Desktop. Run this audit immediately. Finish was clicked to start the cracking job.

Figure 12: LC7 Summary wizard full audit configuration confirmed before execution

Figure 13: L0phtCrack Cracking in Progress

L0phtCrack began cracking. The status bar showed 'JTR Engine: Pass 1/1 (NTLM): Elapsed Time 0d0h1m13s'. The accounts table populated with results: Guest No Password (instantly), DefaultAccount No Password (instantly), jason qwerty (Dictionary:Complex, 31s), krbtgt Not Cracked, martin apple (Dictionary:Complex, 9s), Administrator Pa$$w0rd (Dictionary:Complex, 30s). The log showed passwords being discovered in real time.

Figure 13: L0phtCrack actively cracking jason:qwerty, martin:apple, Administrator:Pa$$w0rd visible

Figure 14: L0phtCrack Completed 5 of 6 Passwords Cracked

After the cracking job stopped, the final table showed: All Accounts: 6, Cracked: 5, Partially Cracked: 0, Locked Out: 0, Disabled: 3. Five passwords were successfully recovered: Guest (no password), DefaultAccount (no password), jason (qwerty), martin (apple) and Administrator (Pa$$w0rd). Only krbtgt (a Kerberos key distribution account) remained uncracked, which is expected as krbtgt uses a long randomly-generated password.

Figure 14: L0phtCrack complete 5/6 passwords cracked; Status: Stopped

Figure 15: Lab Question 14.2.1.1 Correct Answer: qwerty

The lab question asked: 'Run L0phtCrack and audit the target machine at 10.10.1.16. Find the password of user Jason.' The answer 'qwerty' was entered and scored Correct, matching the password discovered by L0phtCrack.

Figure 15: Lab Question 14.2.1.1 answered correctly Jason's password: qwerty

Lab 2, Task 2: Audit System Passwords Using John the Ripper

Lab Environment: Parrot Security 4.10 (root). The goal was to create local Linux user accounts, combine /etc/passwd and /etc/shadow using unshadow and crack the SHA-512crypt password hashes using John the Ripper with a custom wordlist.

Figure 16: Creating User jason on Parrot Security

After escalating to root using 'sudo su', the command 'adduser --gecos "" jason' was executed to create the first test user. The password 'alpha' was set. The terminal confirmed: Adding user 'jason', creating home directory /home/jason and 'passwd: password updated successfully'. This user will have a weak password detectable by John the Ripper.

Figure 16: adduser jason created with password 'alpha' on Parrot Security

Figure 17: Additional Users Created shiela, sam, larry

Three additional users were created using the same adduser command with the following passwords: shiela (test@123), sam (an assigned password), larry (qwerty@123). Each user creation was confirmed with 'passwd: password updated successfully'. These accounts form the test set for the John the Ripper Linux password audit.

Figure 17: Additional users shiela, sam and larry created with assigned passwords

Figure 18: Passwords.txt Wordlist Viewed in vim

The Passwords.txt wordlist file was copied from /home/attacker/Desktop/EHE Module 07.../Wordlists to the Desktop and opened with vim. The file contained a list of sample passwords including: AAAA$, AAABaaabj$, AAAGH$, apple$, alpha$, test@123, Appell116$ and many others. This wordlist was used as the source dictionary for John the Ripper in the Linux audit.

Figure 18: Passwords.txt wordlist viewed in vim sample passwords shown

Figure 19: John the Ripper Cracks Linux Hashes unshadow + john

The unshadow command merged /etc/passwd and /etc/shadow into target-file. John the Ripper was then run with: 'john --wordlist=/home/attacker/Desktop/Passwords.txt target-file'. It loaded 7 SHA-512crypt password hashes and cracked 4 in under 2 seconds: test@123 (shiela), alpha (jason), qwerty@123 (larry), apple (martin). Session completed with '4g' results noted.

Figure 19: John the Ripper cracks 4 Linux SHA-512crypt hashes using Passwords.txt wordlist

Figure 20: Cracked Passwords Saved to results.txt Displayed in Pluma

The 'john --show target-file > results.txt' command was run to export results, followed by 'pluma results.txt' to display them. The file confirmed: jason:alpha, martin:apple, shiela:test@123, larry:qwerty@123 each with their UID, GID, home directory and shell. The final line read '4 password hashes cracked, 3 left', confirming 4 of 7 accounts had weak passwords recoverable from the wordlist.

Figure 20: results.txt in Pluma 4 cracked passwords: alpha, apple, test@123, qwerty@123

Summary and Observations

Lab 3, Task 1: Responder + John the Ripper

The Responder attack demonstrated how an attacker on the same local network can silently capture NTLMv2 authentication hashes by poisoning LLMNR and NBT-NS broadcast requests. The victim's only observable symptom was a Network Error dialog they had no indication their credentials were being captured. John the Ripper then cracked the captured NTLMv2 hash in seconds using a standard wordlist, recovering the plaintext password 'qwerty'. This confirms that even NTLMv2 hashes are vulnerable when users choose weak passwords.

Lab 2, Task 1: L0phtCrack

L0phtCrack successfully extracted NTLM hashes from Windows Server 2016 remotely via SMB and cracked 5 of 6 passwords within the Thorough audit time window. The results exposed three accounts (jason, martin, Administrator) using dictionary-vulnerable passwords. The krbtgt account, which uses a long randomly-generated key, was the only account not cracked underscoring the importance of strong, non-dictionary passwords for privileged accounts.

Lab 2, Task 2: John the Ripper (Linux)

John the Ripper cracked 4 of 7 Linux SHA-512crypt hashes in under 2 seconds using a 1.5 KB custom wordlist. This illustrates that hash algorithm strength (SHA-512) is not a sufficient defence if the underlying password is weak. The remaining 3 accounts were not cracked because their passwords were absent from the wordlist, highlighting the critical role of password complexity and unpredictability.

Key Security Takeaways

- Disable LLMNR and NBT-NS via Group Policy on all Windows machines to eliminate the Responder attack surface.
- Enforce strong password policies (minimum 12 characters, mixed case, numbers, symbols) to resist dictionary-based NTLMv2 cracking.
- Implement multi-factor authentication (MFA) so that a captured hash alone is insufficient to access resources.
- Audit system passwords regularly using tools like L0phtCrack or John the Ripper to identify and remediate accounts with weak passwords before attackers do.
- Store passwords using modern, salted hashing algorithms (bcrypt, scrypt, Argon2) on Linux systems; avoid legacy MD4/NTLM where possible.
- Monitor for Responder-style attacks using network IDS signatures that detect anomalous NBT-NS/LLMNR responses from unexpected hosts.

References

EC-Council. (2022). Ethical Hacking Essentials (EHE) v1 Module 04: Password Cracking Techniques and Countermeasures. EC-Council Press.

Stallings, W., & Brown, L. (2018). Computer Security: Principles and Practice (4th ed.). Pearson Education.

MITRE ATT&CK. (2023). T1557.001: Adversary-in-the-Middle: LLMNR/NBT-NS Poisoning and SMB Relay. MITRE Corporation. https://attack.mitre.org/techniques/T1557/001/

Openwall Project. (2023). John the Ripper Password Cracker Documentation. https://www.openwall.com/john/

@stake / L0phtCrack LLC. (2020). L0phtCrack 7 Documentation. https://www.l0phtcrack.com/